SportsOS: An AI-Powered Sports ERP for IIT (ISM) Dhanbad

Thesis Mid-Evaluation · 13 November 2026

Anup Kumar
Admission No. 22JE0143 · Integrated M.Tech, Mathematics and Computing
Mentor: Prof. Scindhiya Laxmi
Department of Mathematics and Computing, IIT (ISM) Dhanbad

Where the Project Stands Today

143

API endpoints in 20 modules

31

database models (PostgreSQL)

18 × 70

roles × permissions

375

automated checks, all passing

Done

- Booking, attendance, inventory, tournaments, complaints, analytics
- Scoped, time-bound RBAC with two-person approval
- Hash-chained audit ledger

Partial

- AI assistant: offline mode verified, LLM untested
- Mobile app: type-checked, not run on a phone
- Analytics on synthetic data only

Next

- Validation with SPEC and real data
- Security hardening (password reset, cookies)
- Load, penetration and device testing

Sports at IIT (ISM): The Setting

- Sport is administered under the Dean (Students' Welfare) through the Sports & Physical Education Center (SPEC)
- SPEC organises intramural events, including the Annual Sports Meet and the Inter-Hostel General Championship
- Participation is competitive, inter-hostel and recreational: SportsOS models all three

Lower Ground

Football ground; 8-lane, 400 m floodlit track

Sports Complex

Floodlit basketball, volleyball and tennis courts

Students Activity Centre

Gym, 4 badminton courts, yoga, boxing, billiards

Swimming Pool

50 m standard-size pool

Source: SPEC activity and facilities pages, people.iitism.ac.in/~dsw/spec (undated; to be re-confirmed with SPEC)

Problem: Fragmented, Unauditable Operations

No centralised records

Attendance, equipment logs and complaints live in separate paper books

No real-time visibility

No live view of court availability, ground status or stock

Proxy-prone attendance

Paper sign-in sheets are easy to manipulate and hard to audit

No data for decisions

No metrics on participation, demand or equipment wear

Why this is worth a thesis

- Sports-digitalisation research studies one solution for one stakeholder; multi-stakeholder systems are a stated gap (Haffner et al., 2025)
- Integrated sports-facility MIS improve service quality but remain little studied (Saputra & Asmawati, 2025)
- Broken access control is the #1 web-application risk (OWASP); 18 roles make this a realistic test bed

Research Objectives (Unchanged from Proposal)

O1 · Centralise

Booking, tournaments, attendance, inventory and events in one platform

O2 · Automate

Scheduling, approvals, record management and reporting

O3 · Role-based access

Secure, customised access for every stakeholder

O4 · Analytics

Dashboards and reports for data-driven decisions

O5 · Student experience

One portal for bookings, check-in, notifications

O6 · Future-ready

Secure, scalable, able to host AI features

Related Work and Research Gap

Work	Setting	Attendance proof	Access control	Audit trail
Haffner et al. 2025	IS review, sports digitalisation	—	Stakeholder lens	—
Saputra & Asmawati 2025	Review, sports facilities	Not reported	Not reported	Not reported
Shahrom & Mohamad Sukri 2025	University pool system	No (OTP for login)	RBAC + 2FA	Not reported
Sandhu et al. 2000 (NIST)	RBAC reference model	—	Flat → symmetric RBAC	—
SportsOS	Institute-wide campus sports	TOTP + GPS + device	Scoped, time-bound	SHA-256 hash chain

Gap: no integrated, verifiable system for an academic sports ecosystem where office-bearers hold only scoped authority, attendance must be provably physical, records must stay consistent and auditable, and authorisation is tested across every role.

Requirements: 18 Stakeholder Roles

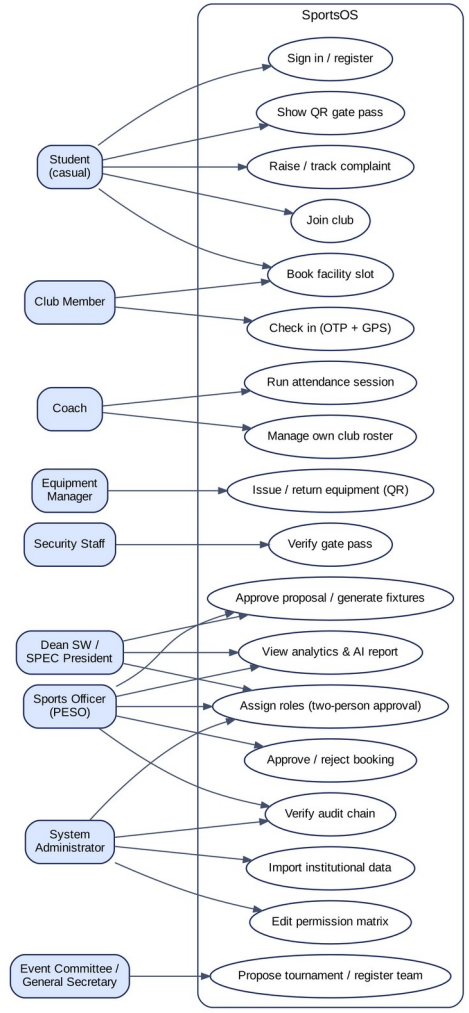
18 roles

70 permissions

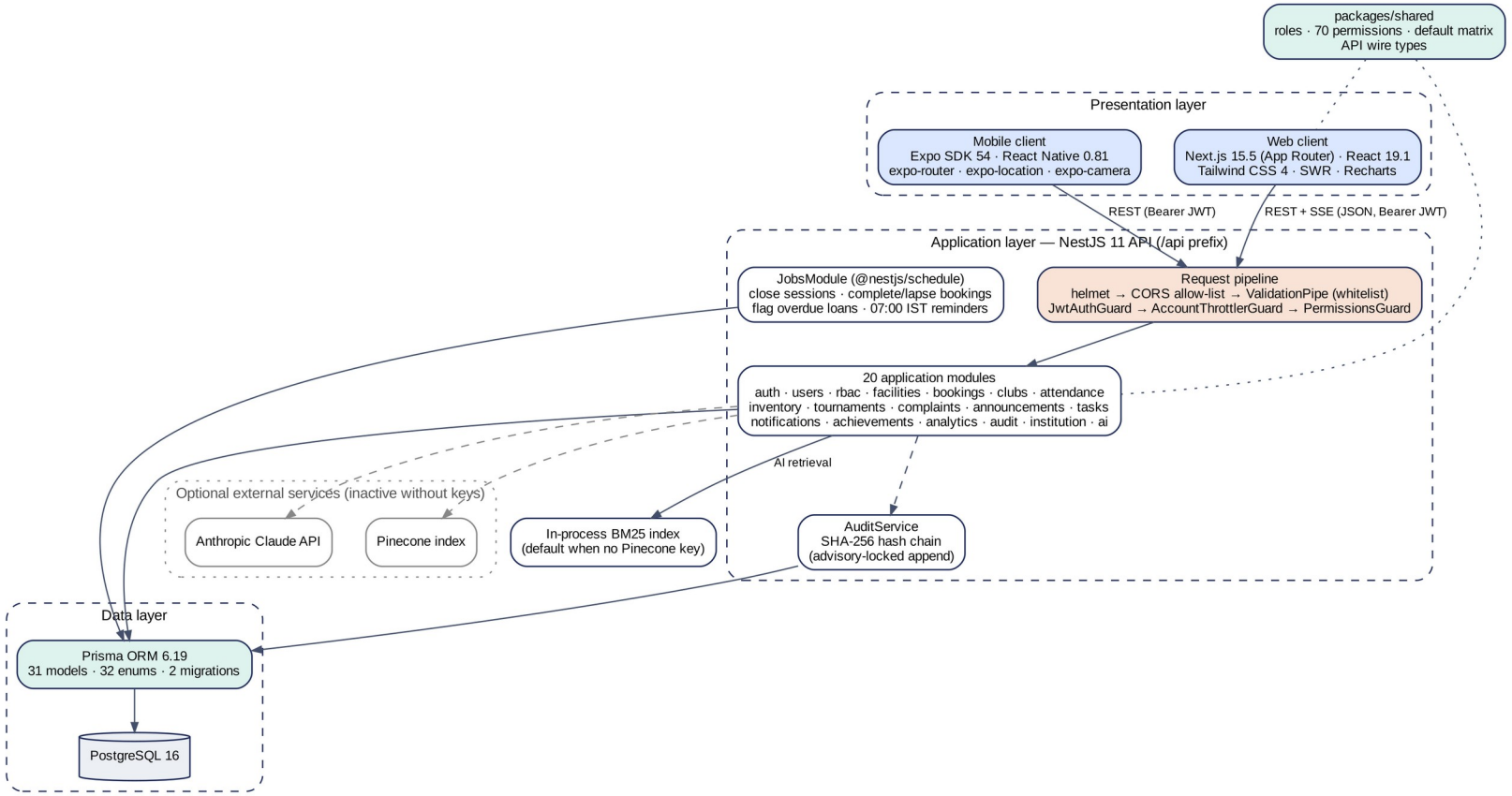
4 scope types

346 default grants

- Scopes: club, hostel, sport, facility; time-bound roles lapse automatically
- Seniority grants nothing: a Director sees dashboards but cannot approve bookings
- Hierarchy is the proposal's model, used only for the org chart; to be validated with SPEC



System Architecture



Modular monolith

20 NestJS modules share one transactional database

Three global guards

Authenticate → rate-limit per account → authorise

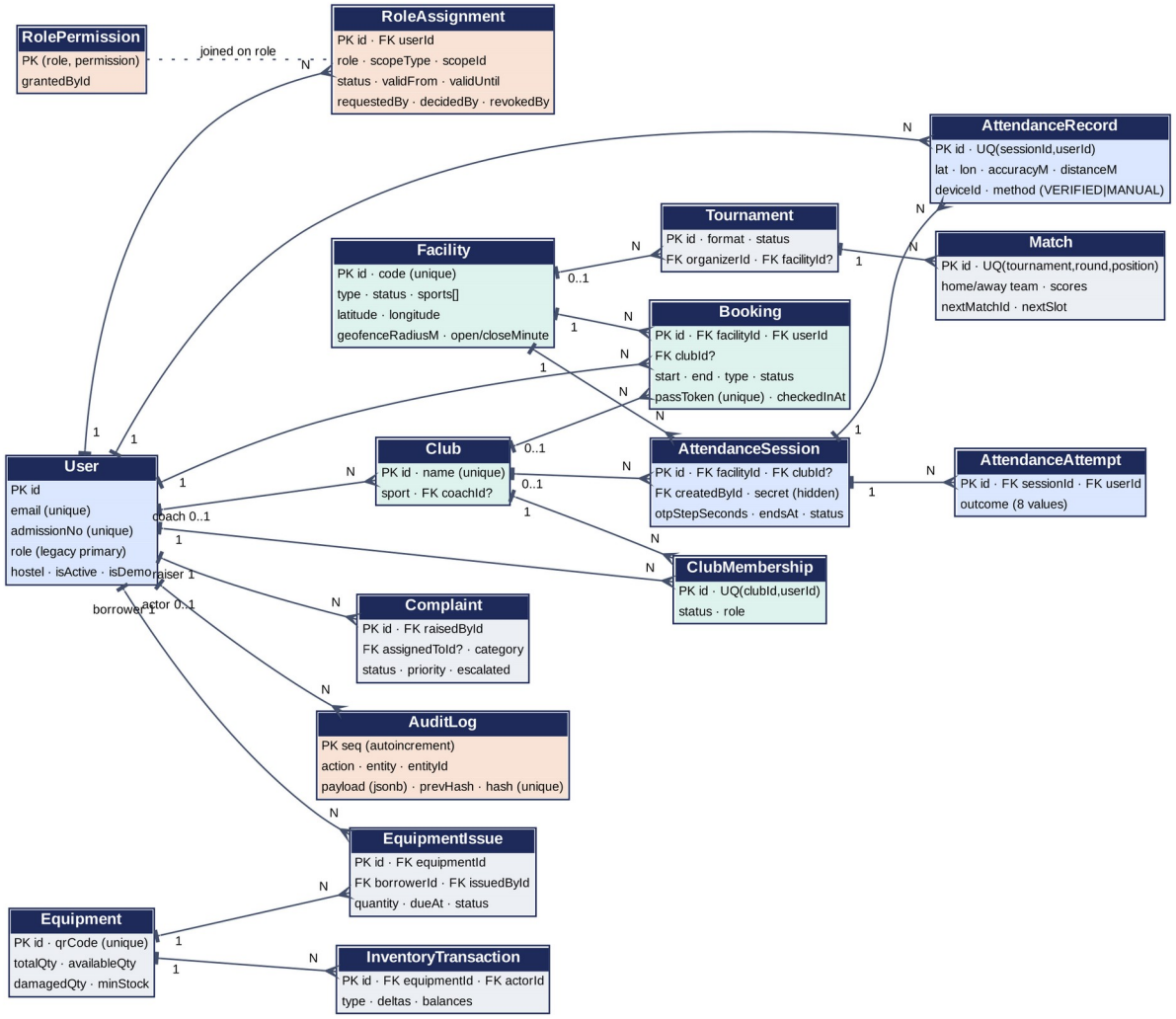
One shared package

Roles, permissions and types reused by API and web

Optional AI

Claude and Pinecone inactive without keys; offline fallback

Database Design: Integrity Enforced by PostgreSQL



31 models · 32 enums · 2 migrations

Unique constraints

One attendance record per student per session

Advisory locks

Bookings serialised per facility; audit appends serialised

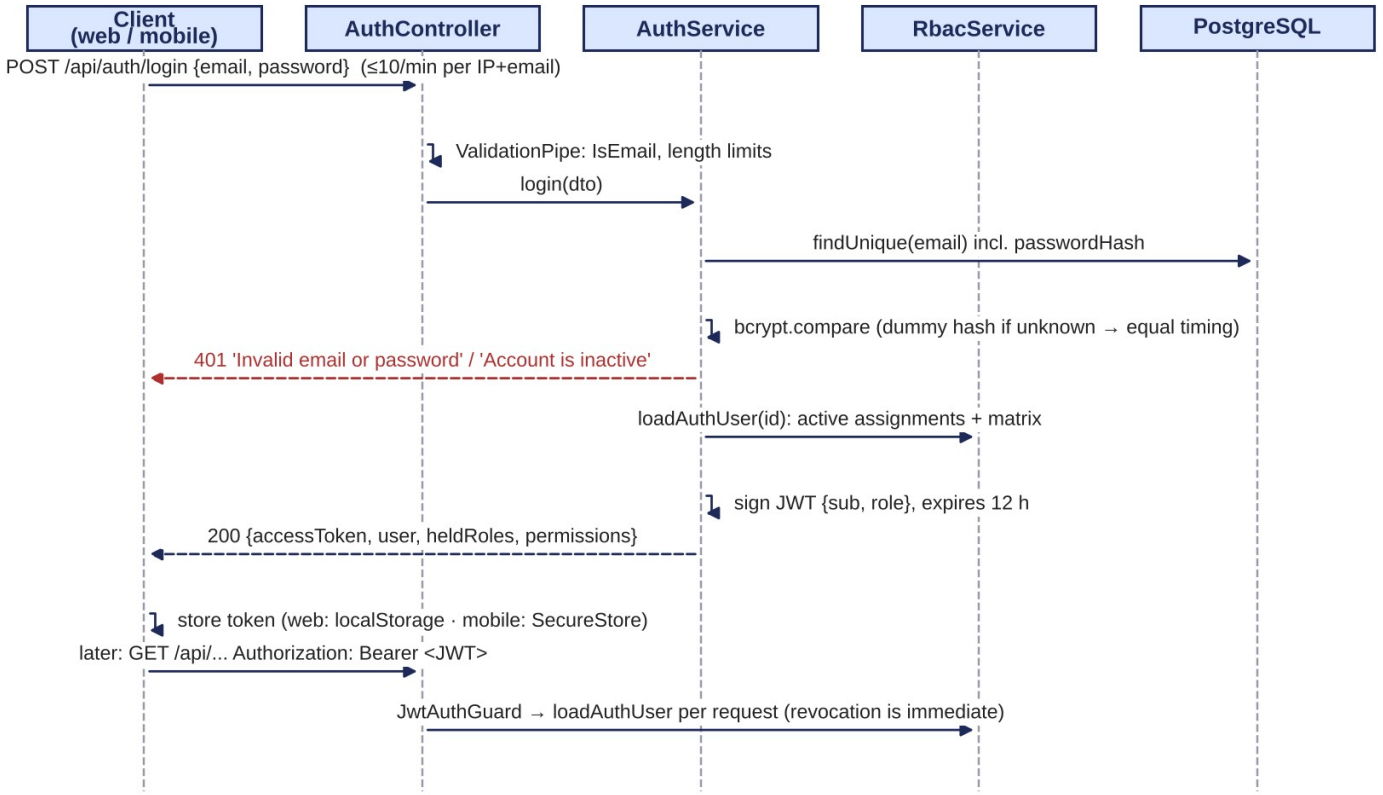
Conditional updates

UPDATE … WHERE available ≥ n: stock never negative

History, not deletion

Roles, stock moves and corrections are append-only

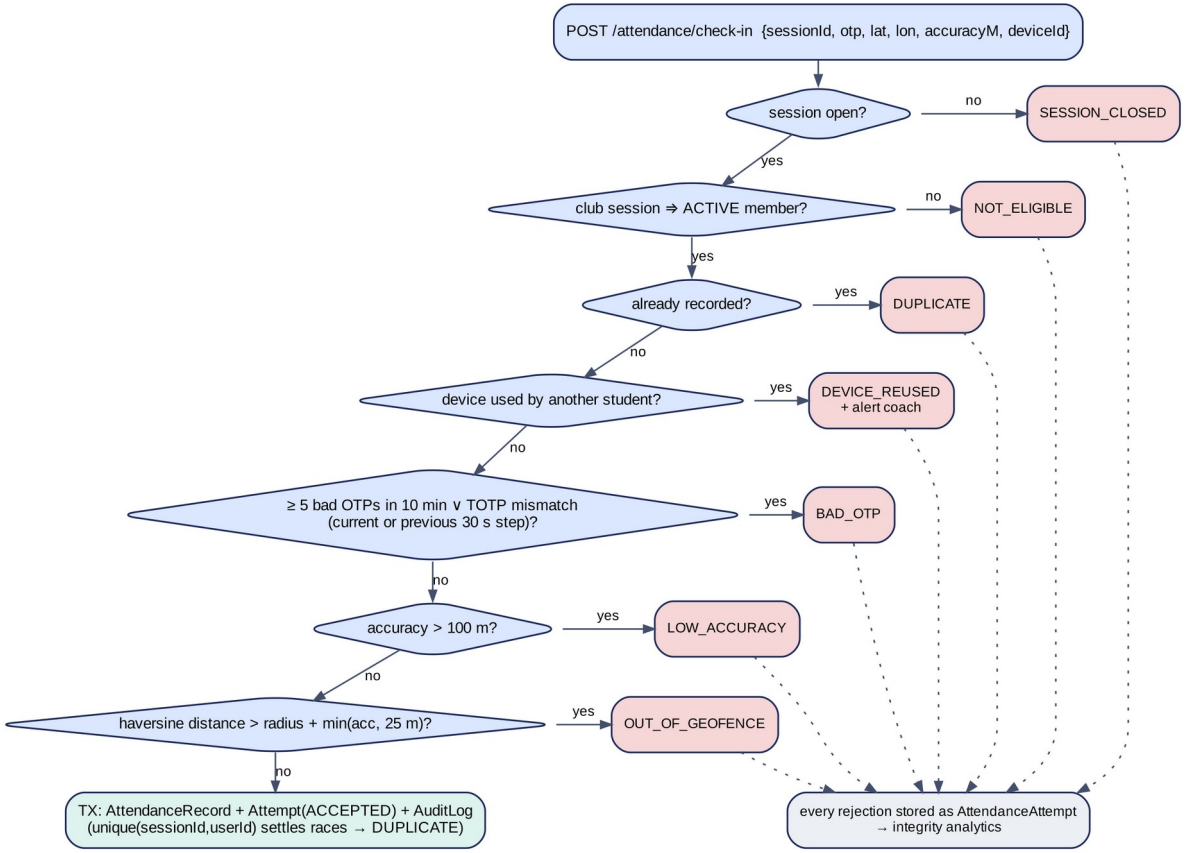
Authentication and Role-Based Access Control

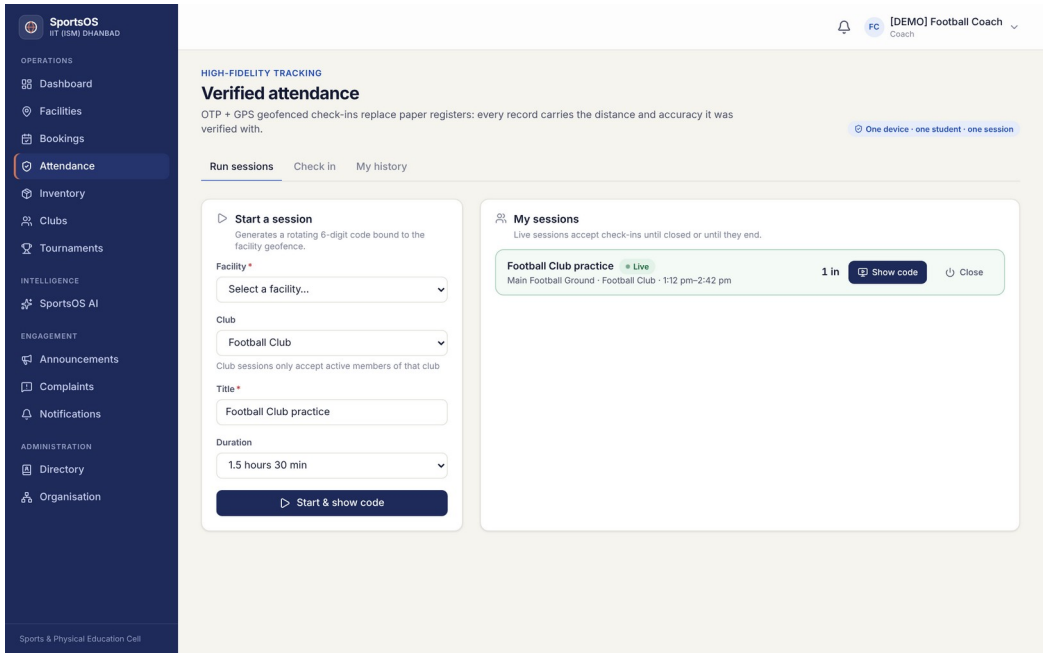


Login and authenticated request (from auth.service.ts and guards.ts)

- bcrypt hashes; login throttled; timing-equalised for unknown emails
- 12-hour JWT, but the user is reloaded from the database on every request, so revocation is immediate
- Active-role header must name a held role, otherwise 403
- Object-level scope checks: a coach manages only clubs they coach
- Privileged roles need approval by a second person

Verified Attendance: OTP + GPS + Device

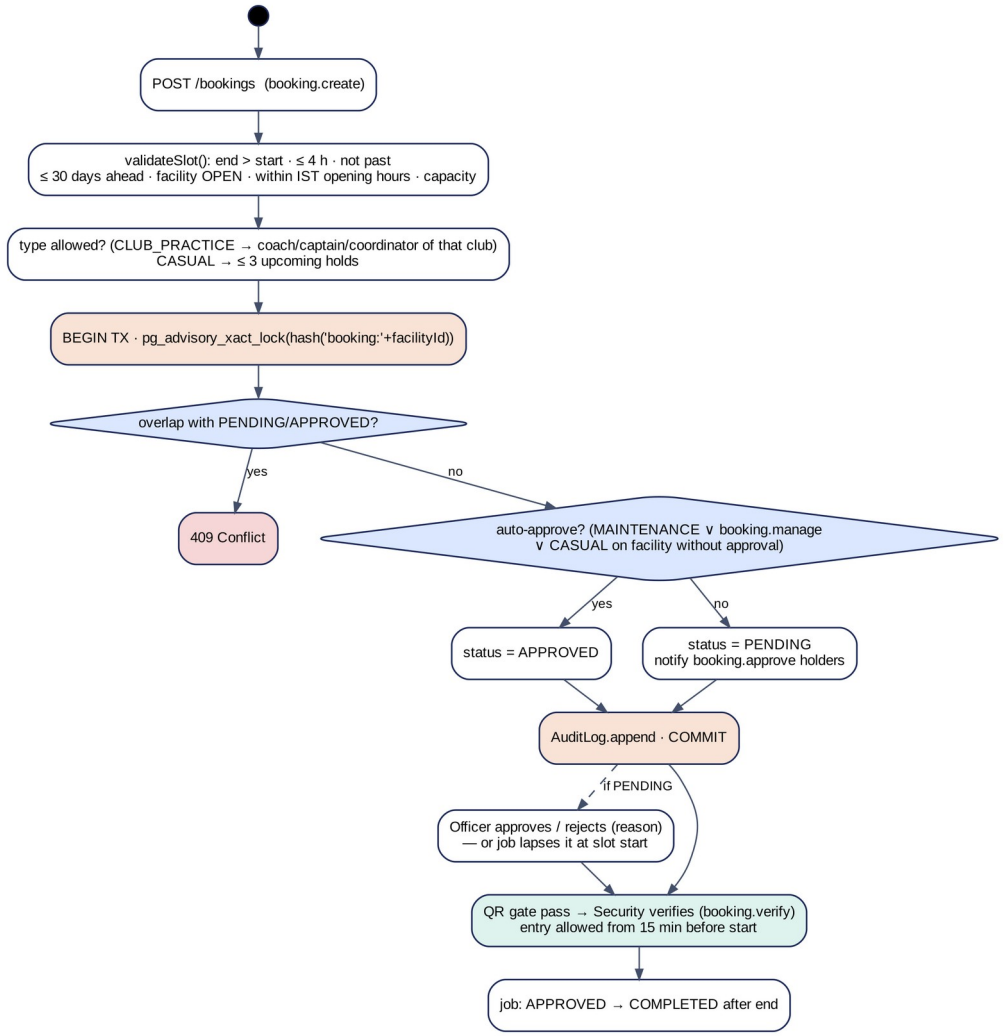




Coach console with a live session (synthetic demo data)

- 6-digit code rotates every 30 s (RFC 6238 TOTP)
- GPS accuracy ≤ 100 m; distance ≤ radius + min(accuracy, 25 m)
- Every attempt logged; device reuse alerts the coach

Booking and Inventory Stay Consistent



6 → 1 six simultaneous requests for one slot: exactly one booking created, five refused (409)

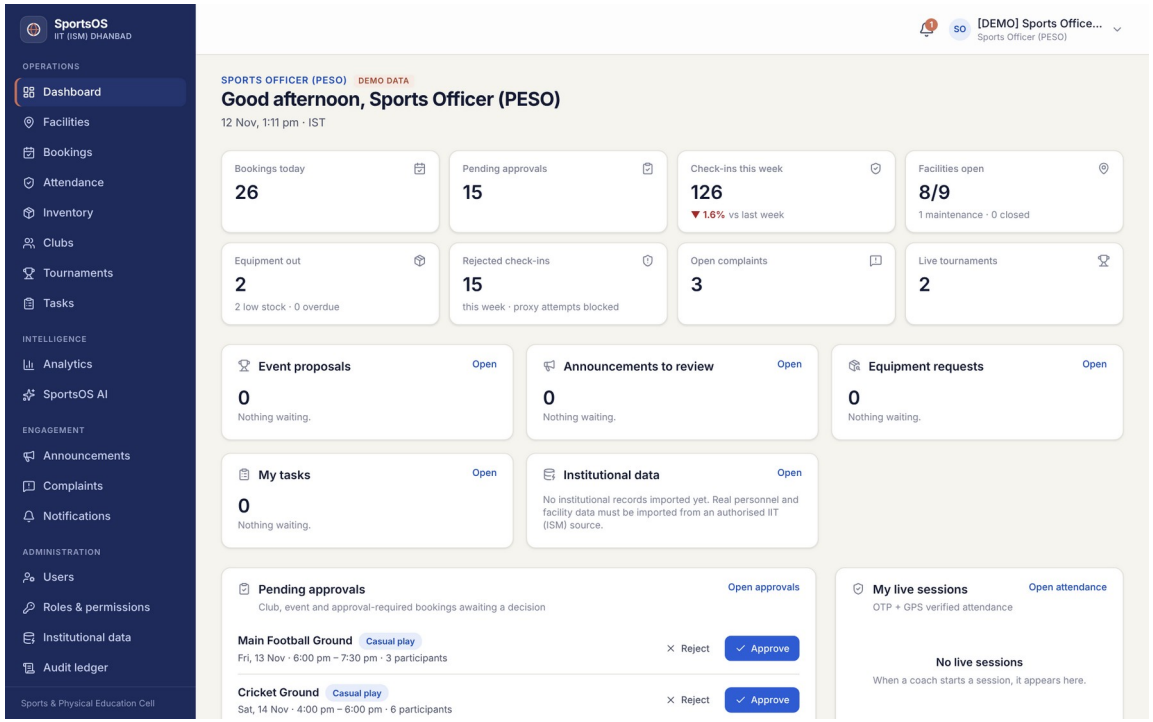
8 → 3 eight simultaneous issues against 3 units in stock: exactly three succeed

0 difference between ledger totals and stored stock after all movements

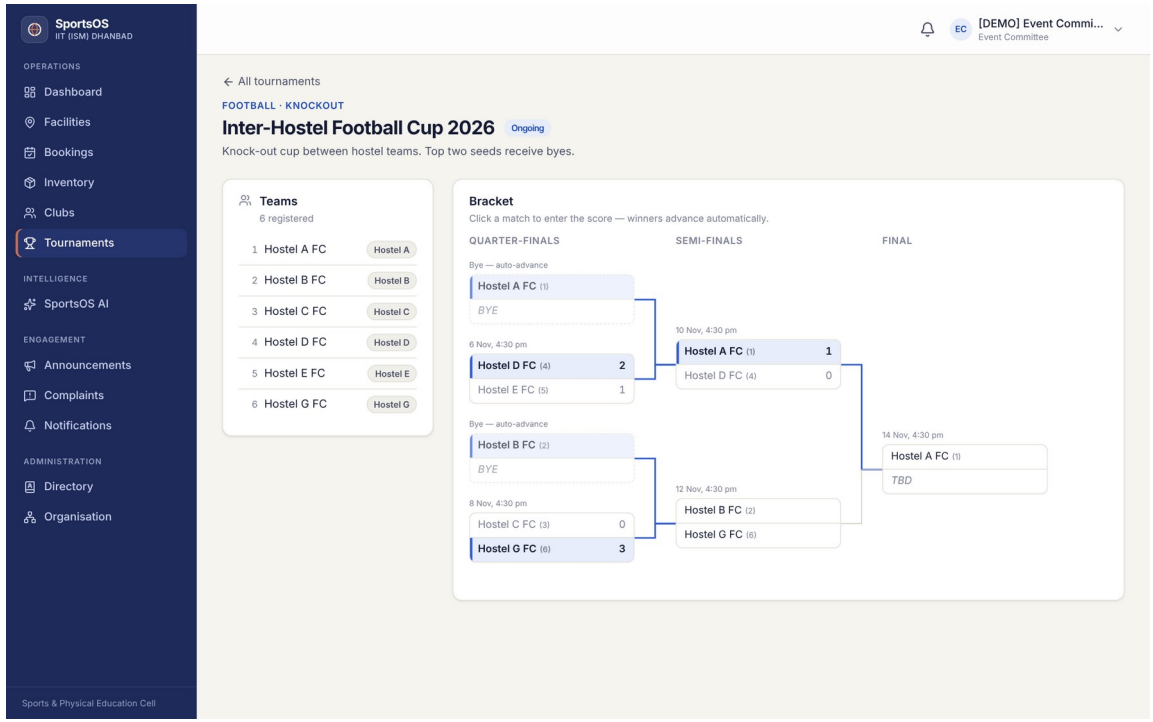
Module-Wise Implementation Status

Authentication & users Tested	RBAC (scoped, two-person) Tested	Facilities & booking Tested	QR gate pass Tested
Clubs & rosters Tested	OTP + GPS attendance Tested	Inventory ledger & QR Tested	Tournaments & fixtures Tested
Complaints & tasks Tested	Announcements & notifications Tested	Analytics & audit ledger Tested	Institutional data import Tested
AI assistant Partial	Mobile app Partial	Password reset · Redis Not built	Cloud deployment Planned

Working Prototype



Sports Officer dashboard: KPIs and approval queue



Knock-out bracket with seeded byes and auto-advancement

All screens show synthetic demo data; no real student or staff records are used.

Verification Results (Run on 12 Nov 2026)

71 / 71	83 / 83	200 / 200	21 / 21	19 / 19
Unit tests	**API smoke checks**	**RBAC & workflow**	**Browser checks**	**Demo logins**
OTP vectors, geofence, hash chain, RBAC	Every module, end to end	23 endpoints × 18 roles + workflows	9 roles, 12 interactive flows	Every seeded role account

- Fresh database (prisma migrate deploy + synthetic seed), production builds, TypeScript and ESLint clean (0 errors)
- Previously reported demo-login failures and duplicate port-4000 processes could not be reproduced
- Preliminary: no load, penetration, device or user testing yet

Representative Test Cases

ID	Scenario	Expected	Actual	Status
AUTH-02	Invalid login (unknown account)	401	401	PASS
RBAC-01	Student calls analytics endpoint	403	403	PASS
ATT-02	Football coach opens Basketball session	403	403	PASS
BK-04	6 concurrent requests for one slot	1 succeeds	201 ×1, 409 ×5	PASS
ATT-05	Correct code, 1.1 km away	OUT_OF_GEOFENCE	1,112 m, rejected	PASS
INV-03	Return with one damaged unit	Stock updated	available 13 → 12	PASS
DB-03	Data survives API restart	Counts unchanged	2,798 → 2,798 bookings	PASS
AUTH-09	Forgot-password request	Reset flow	404	Not built

Full tables (63 cases) are in Appendix F of the report

Achievement Against Objectives

O1	**Centralise operations**	One schema and API for all modules	Met
O2	**Automate administration**	Approval workflows, 4 scheduled jobs, import rollback	Met
O3	**Role-based access**	18 roles, 70 permissions; 200/200 checks	Met
O4	**Analytics**	Dashboards and forecast, synthetic data only	Partly met
O5	**Student experience**	Web portal done; mobile not device-tested; no user study	Partly met
O6	**Future-ready**	No cloud, load test, live AI or shared cache yet	Partly met

Current Limitations

No password reset

Needs an approved email channel

Web token in localStorage

Move to httpOnly cookie session

No Redis

Rate limits and cache are per process

10 dependency advisories

7 high; to triage and upgrade

Mobile not run on a phone

GPS and camera unverified

AI verified offline only

No keys; LLM path mocked

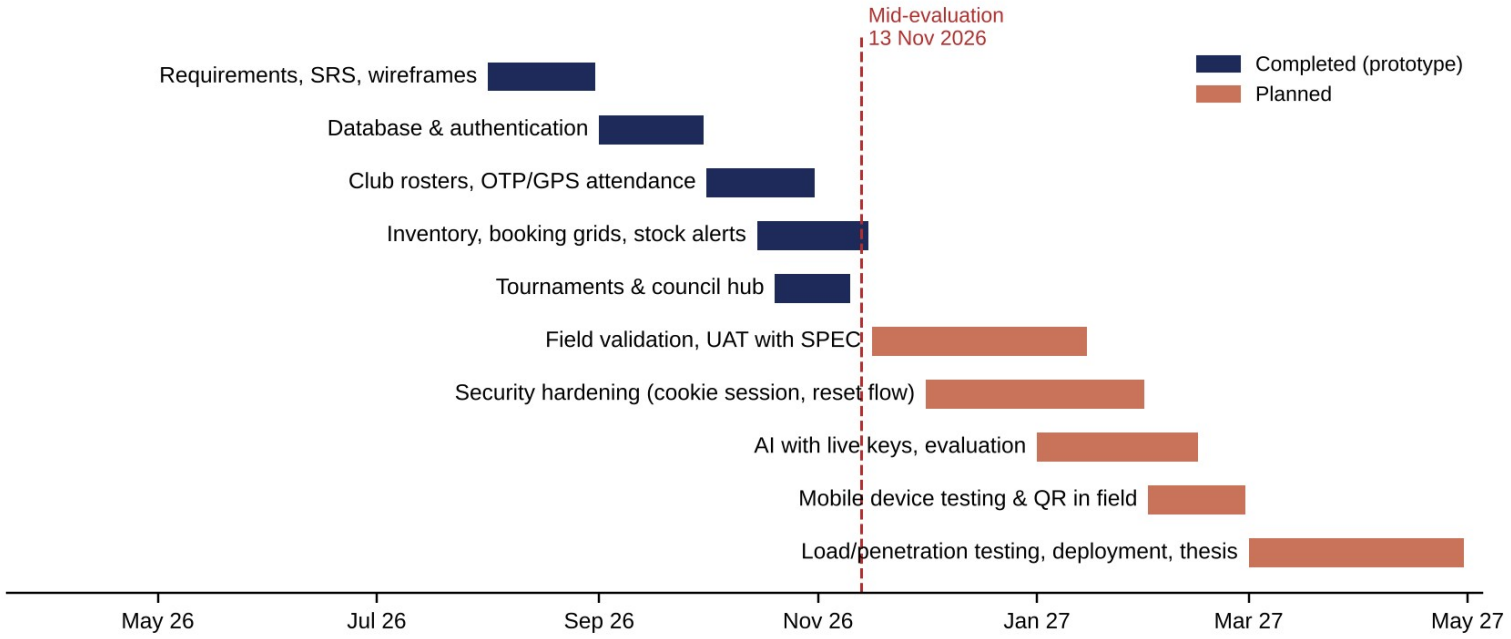
Synthetic data only

Geofences are placeholders

No load or pen testing

Containers configured, not run

Revised Roadmap (Nov 2026 – Apr 2027)



Core modules (Sep–Dec milestones) finished early, so the remaining months move to validation and hardening.

Nov–Jan	SPEC validation, UAT, ground survey
Dec–Jan	Security hardening
Jan–Feb	Live AI evaluation
Feb	Mobile device testing
Mar–Apr	Load and penetration tests, staging, thesis

Key References

[1] L. Haffner, I. Oshri, J. Kotlarsky, "Directions for future IS research on sports digitalisation: A stakeholder perspective," J. Strategic Inf. Syst., 34(2), 101905, 2025.

[2] D. E. W. Saputra, P. Asmawati, "Elevating user experience and service excellence in sports facilities via integrated management information systems: A systematic review," Sports Science and Health, 15(V), 111–118, 2025.

[3] M. D. Shahrom, K. A. Mohamad Sukri, "Swimming facilities management system for UTHM Sport Centre with two-factor authentication," Applied IT and Computer Science, 6(2), 625–643, 2025.

[4] R. Sandhu, D. Ferraiolo, R. Kuhn, "The NIST model for role-based access control: Towards a unified standard," Proc. 5th ACM RBAC Workshop, 47–63, 2000.

[5] OWASP Foundation, Application Security Verification Standard 5.0.0, May 2025.

[6] SPEC, IIT (ISM) Dhanbad, "Activities" and "Facilities," people.iitism.ac.in/~dsw/spec (undated).

[7] D. M'Raihi et al., "TOTP: Time-based one-time password algorithm," IETF RFC 6238, 2011.

Conclusion

- SportsOS is a working, tested prototype: one system for booking, verified attendance, inventory, tournaments, complaints and analytics
- Verified claims: access confined to role and scope; attendance needs physical presence; records consistent under concurrency; every change audited
- Open: real data, device and field testing, live AI, security hardening, deployment

Thank you · Questions?